هم‌رسان: نسخه‌های بین‌سازمانی و سازمانی

گزارش کار، توضیح سازوکار و الگوریتم‌ها، و وضعیت آزمون‌ها · نسخهٔ ۴٫۰ سند · ۱۴۰۵/۰۷/۲۹ · برنامهٔ ۱٫۰٫۰ (۱۷۴)، پنل صدور ۱٫۴

تازه در نسخهٔ ۴٫۰ (۱۴۰۵/۰۷/۲۹)، بر پایهٔ نظر منتور که «وقتی اینترنت نیست، عضو تازه نباید به فایل تازه برای همه نیاز داشته باشد»:

- **فایل کلید فقط کلید و گواهی خود عضو است** (۲۶۱ بایت). دفترچهٔ سازمان (فهرست اعضا) و فایل به‌روزرسانی (`update.hku`) از برنامه، پنل و ابزار خط فرمان حذف شدند. هیچ نام، شماره یا فهرستی از اعضا روی گوشی‌ها نیست (بخش ۹).
- **پیام رمز به هر شماره:** کاربر یکی را از مخاطبین انتخاب می‌کند یا شماره‌اش را می‌نویسد. اگر آن شماره هم‌رسانِ دارای کلید سازمانی داشته باشد، کانال امن با گواهی‌ها برقرار می‌شود. اگر نداشته باشد، هیچ اتفاقی نمی‌افتد (بخش ۶-۲).
- **هر تغییر در سازمان فقط فایل همان عضو را عوض می‌کند:** افزودن، ویرایش، «گوشی گم شد» و حذف.
- **بخش امن رمز ۶ رقمی جداگانه** و اثر انگشت جداگانه دارد (بخش ۸).
- **حالت‌های شکست دیده می‌شوند:** اگر درخواست کانال امن فرستاده نشود یا جوابی نیاید، کاربر پیام و دکمهٔ «دوباره تلاش» می‌بیند. ارتقای پساکوانتومی کاملاً در پس‌زمینه است و عنوان گفتگو فقط «رمزشده» می‌گوید (بخش ۶-۲).
- **یک اشکال جدی پیدا و رفع شد:** پیشنهاد ارتقایی که دیر در شبکه رسید، جلسهٔ درست را پاک می‌کرد و بعد از آن پیام‌های یک طرف خوانده نمی‌شد (بخش ۱۶).
- **پیامک عادی مخاطب مخفی** گفتگو و فهرست جداگانه دارد و با پیام رمز همان شخص قاطی نمی‌شود (بخش ۱۲).
- **مرجع تازه** با شناسهٔ `7fda025a5a997b93` ساخته شد و جای مرجع قبلی را در برنامه گرفت (بخش ۱۰).

این سند برای کسی نوشته شده که هم‌رسان را ندیده است: مدیر محصول، کارشناس امنیت، منتور پروژه یا هر کس دیگری که باید تصمیم بگیرد. هر جا اسم یک الگوریتم یا اصطلاح فنی آمده، همان‌جا با زبان ساده گفته‌ایم چیست و چرا انتخاب شده است. واژه‌نامه هم در انتهای سند هست.

اگر فقط می‌خواهید بدانید با برنامه چطور کار کنید، «راهنمای کاربر نسخهٔ بین‌سازمانی» را بخوانید؛ کار با پنل ویندوزی هم در «راهنمای پنل صدور هم‌رسان» آمده است.

فهرست

۱. هم‌رسان چیست
۲. سه نسخه و تفاوتشان
۳. کد فعال‌سازی نسخهٔ بین‌سازمانی
۴. رمزنگاری به زبان ساده
۵. الگوریتم‌هایی که به کار رفته و چرا
۶. مسیر یک پیام رمز از نوشتن تا خوانده شدن
۷. اپراتور و برنامه‌های دیگر چه می‌بینند
۸. بخش امن
۹. بانک کلید، فایل کلید و گواهی عضو
۱۰. پوشهٔ مرجع کلید
۱۱. پیام رمز گروهی
۱۲. دفترچهٔ تلفن مخفی
۱۳. قابلیت‌های امنیتی دیگر
۱۴. نقشهٔ استفاده از برنامه، با تصویر
۱۵. تطبیق با پیوست فنی
۱۶. آزمون‌ها
۱۷. محدودیت‌ها و تصمیم‌های باز
۱۸. واژه‌نامه

۱. هم‌رسان چیست

هم‌رسان یک برنامهٔ اندرویدی فارسی است که سه کار اصلی گوشی را یک‌جا انجام می‌دهد: پیامک، تماس تلفنی و دفترچهٔ تلفن. کاربر آن را به‌جای برنامهٔ پیامک و تلفن خود گوشی انتخاب می‌کند. در نسخهٔ معمولی، هم‌رسان یک پیام‌رسان و شماره‌گیر کامل است.

نسخه‌های امن هم‌رسان یک کار دیگر هم می‌کنند: **پیامک را رمز می‌کنند.** دو نفری که هر دو هم‌رسان امن دارند، از طریق همان پیامک معمولی اپراتور پیامی می‌فرستند که هیچ‌کس جز خودشان نمی‌تواند بخواند. اپراتور، کسی که سیم‌کارت را شنود می‌کند و برنامه‌های دیگر گوشی فقط یک رشتهٔ نامفهوم می‌بینند.

چرا پیامک و نه اینترنت؟ پیامک بدون اینترنت کار می‌کند و در اختلال یا قطع اینترنت از کار نمی‌افتد. به سرور هم نیاز ندارد، پس سروری نیست که از کار بیفتد، هک شود یا اطلاعات کسی را نگه دارد. پیام مستقیم از سیم‌کارت یک نفر به سیم‌کارت نفر دیگر می‌رود. به همین دلیل همهٔ طراحی این سند یک شرط دارد: **هیچ مرحله‌ای به اینترنت نیاز ندارد.** تنها چیزی که باید جدا از پیامک به دست کسی برسد، فایل کلید خود اوست.

۲. سه نسخه و تفاوتشان

کد برنامه یکی است، اما سه نسخه از آن ساخته می‌شود که در قالب دو فایل نصبی (APK) عرضه می‌شوند:

نسخه	از کجا نصب می‌شود	چه فرقی دارد
تجاری	فروشگاه‌ها (بازار، مایکت)	پیامک، تماس و مخاطبین معمولی. هیچ قابلیت امنی ندارد و پیام رمز نه می‌فرستد و نه می‌خواند.
بین‌سازمانی	همان فایل تجاری؛ با کد فعال‌سازی داخل برنامه باز می‌شود	همهٔ قابلیت‌های امن: بخش امن، پیام رمز، گروه رمز، دفترچهٔ مخفی و بقیه. مناسب ارتباط بین چند سازمان.
سازمانی	فایل نصبی جداگانه، فقط توزیع مستقیم و هرگز در فروشگاه	همهٔ قابلیت‌های بین‌سازمانی بدون نیاز به کد فعال‌سازی، به‌علاوهٔ «متن پوششی» (بخش ۷-۳). گزارش خطا از این نسخه کاملاً حذف شده تا با هیچ سرور بیرونی تماس نگیرد.

- هر دو فایل شناسهٔ یکسان دارند (`ir.hamrasan.app`) و با یک کلید امضا ساخته می‌شوند. اندروید آن‌ها را یک برنامه می‌بیند، پس نصب یکی روی دیگری اطلاعات را از بین نمی‌برد.
- فروشگاه نسخهٔ سازمانی را با نسخهٔ عادی عوض نمی‌کند. هر برنامهٔ اندرویدی یک شمارهٔ نسخهٔ داخلی دارد (versionCode) و فروشگاه فقط وقتی به‌روزرسانی پیشنهاد می‌دهد که شمارهٔ خودش بزرگ‌تر باشد. شمارهٔ نسخهٔ سازمانی از دو میلیارد شروع می‌شود و نسخهٔ فروشگاهی عددی کوچک است (امروز ۱۷۴).
- اسکریپت ساخت نسخهٔ نهایی بعد از ساخت فایل بررسی می‌کند که شناسه، شمارهٔ نسخه و امضا درست باشند و کلید آزمایشی داخل فایل نرفته باشد.

۳. کد فعال‌سازی نسخهٔ بین‌سازمانی

نسخهٔ بین‌سازمانی همان فایل فروشگاهی است. برای اینکه قابلیت‌های امن روی هر گوشی فقط با اجازه باز شود، برنامه یک کد فعال‌سازی ۱۰ نویسه‌ای می‌خواهد که مخصوص همان گوشی است. برای ساختنش اینترنت و سرور لازم نیست. قالب این کد عیناً همان قالب نرم‌افزار قبلی منتور است (S2MS، فایل Activation.java)، تا برنامهٔ ویندوزی تولید کد بدون تغییر کار کند.

۳-۱. مراحل، قدم به قدم

۱. شناسهٔ یکتای گوشی
اندروید به هر برنامه روی هر گوشی یک شناسهٔ ۱۶ نویسه‌ای می‌دهد به نام ANDROID_ID. این شناسه برای هر گوشی فرق دارد و با بازگشت به تنظیمات کارخانه عوض می‌شود. برنامه آن را به کسی نشان نمی‌دهد.

۲. کد دستگاه (۶ نویسه)
برنامه از این شناسه با الگوریتم BLAKE3 یک «اثر انگشت» می‌سازد و ۳ بایت اولش را به شکل ۶ نویسهٔ هگز (۰ تا ۹ و a تا f) نشان می‌دهد. نمونه: `a88129`

۳. ترکیب با شناسهٔ برنامه
نویسه‌های کد دستگاه یکی‌درمیان با شناسهٔ ثابت برنامه، یعنی `111111` ، کنار هم چیده می‌شوند و یک رشتهٔ ۱۲ نویسه‌ای می‌سازند: `a18181112191`

۴. کد فعال‌سازی (۱۰ نویسه)
از این رشته دوباره اثر انگشت BLAKE3 گرفته می‌شود و ۵ بایت اولش، یعنی ۱۰ نویسهٔ هگز، کد فعال‌سازی است: `54350f2824`

کاربر کد دستگاه را تلفنی یا حضوری به پشتیبانی می‌گوید. پشتیبانی آن را در برنامهٔ ویندوزی وارد می‌کند و کد فعال‌سازی را می‌گیرد. کاربر کد را در گوشی وارد می‌کند. گوشی همان محاسبه را خودش انجام می‌دهد و اگر دو نتیجه یکی بود، نسخهٔ بین‌سازمانی باز می‌شود.

نمونه	کد دستگاه	رشتهٔ ترکیبی	کد فعال‌سازی
گوشی هواوی آزمون (۱۴۰۵/۰۷/۲۹)	`a88129`	`a18181112191`	`54350f2824`
نمونهٔ مرجع برای آزمون برنامهٔ ویندوزی شما	`b60966`	`b16101916161`	`9c4a48e93a`

۳-۲. چند نکتهٔ کاربردی

- مسیر در برنامه: تنظیمات ← «درباره برنامه» ← «نسخه بین‌سازمانی». این گزینه فقط در فایل فروشگاهی هست، چون نسخهٔ سازمانی به کد نیاز ندارد.
- هنگام وارد کردن کد، بزرگی و کوچکی حروف، فاصله، خط تیره و ارقام فارسی اهمیتی ندارد. کد اشتباه با پیام «کد فعال‌سازی درست نیست» رد می‌شود.
- برنامه هر بار کد ذخیره‌شده را دوباره با همان گوشی بررسی می‌کند. اگر اطلاعات برنامه به گوشی دیگری منتقل شود یا گوشی به تنظیمات کارخانه برگردد، نسخه دیگر فعال نیست.
- «غیرفعال کردن» برنامه را به نسخهٔ تجاری برمی‌گرداند. محتوای بخش امن پاک نمی‌شود و با همان کد برمی‌گردد. این را در ۱۴۰۵/۰۷/۲۹ روی هواوی دوباره آزمودیم.

چرا BLAKE3؟ چون نرم‌افزار قبلی و برنامهٔ ویندوزی منتور از همین الگوریتم استفاده می‌کردند و قرار بود سازگار بمانیم. BLAKE3 یک تابع هش استاندارد و سریع است (بخش ۴-۴).

محدودیت این روش: کل روش ساخت کد داخل فایل نصبی است. کسی که فایل را مهندسی معکوس کند، می‌تواند برای هر گوشی کد بسازد. کد هم قابل باطل کردن نیست، چون سروری وجود ندارد. این روش جلوی استفادهٔ عادی و بی‌اجازه را می‌گیرد، ولی در برابر یک متخصص مقاوم نیست. امنیت پیام‌ها به این کد وابسته نیست: کسی که کد فعال‌سازی جعل کند، بدون فایل کلیدی که مرجع امضا کرده نمی‌تواند پیام رمز کسی را بخواند یا به نام کسی پیام بفرستد. راه محکم‌تر در بخش ۱۷ آمده است.

۴. رمزنگاری به زبان ساده

این بخش برای کسی است که با رمزنگاری آشنا نیست. بقیهٔ سند بر همین چند مفهوم بنا شده است.

۴-۱. رمزنگاری متقارن: یک کلید برای قفل و باز کردن

> **مثال:** صندوقی که با یک کلید هم قفل می‌شود و هم باز. هر کس کلید را دارد، هم چیزی داخلش می‌گذارد و هم بیرون می‌آورد.

در رمزنگاری متقارن، فرستنده و گیرنده **یک کلید مشترک** دارند. سریع است و برای رمز کردن خود متن پیام عالی است. هم‌رسان برای این کار AES-256 را به کار می‌برد. مشکلش این است که کلید مشترک اول باید به دست هر دو طرف برسد، و اگر آن را با پیامک بفرستیم، اپراتور هم می‌بیندش.

۴-۲. رمزنگاری نامتقارن: کلید عمومی و کلید خصوصی

> **مثال:** صندوق پستی جلوی خانه. شکاف صندوق برای همه باز است و هر کس نامه‌ای داخلش می‌اندازد: این کلید عمومی است. اما فقط صاحب‌خانه کلید در صندوق را دارد: این کلید خصوصی است.

در رمزنگاری نامتقارن، هر نفر یک جفت‌کلید دارد: کلید عمومی که به همه داده می‌شود و کلید خصوصی که هرگز از گوشی خودش بیرون نمی‌رود. دو نفر بدون اینکه قبلاً رازی را رد و بدل کرده باشند، با کلیدهای عمومی همدیگر به یک کلید مشترک می‌رسند. این کار «توافق کلید» نام دارد.

هم‌رسان هر دو روش را با هم به کار می‌برد، مثل همهٔ سامانه‌های امن امروزی: با رمزنگاری نامتقارن یک کلید مشترک ساخته می‌شود و با رمزنگاری متقارن متن پیام‌ها رمز می‌شود. اولی مشکل رساندن کلید را حل می‌کند و دومی سریع و کم‌حجم است.

۴-۳. امضای دیجیتال: مهری که جعل نمی‌شود

> **مثال:** مهر و امضای مدیر پای یک نامهٔ رسمی. هر کس نمونهٔ امضا را دیده باشد، اصل بودنش را تشخیص می‌دهد، ولی فقط خود مدیر می‌تواند آن را بزند. در امضای دیجیتال، اگر حتی یک حرف نامه بعد از امضا عوض شود، امضا دیگر معتبر نیست.

در هم‌رسان، «مرجع کلید» سازمان برای هر عضو یک **گواهی** امضا می‌کند: «این کلید مال این شمارهٔ همراه است». برنامهٔ روی گوشی فقط کلید عمومی مرجع را دارد. با آن امضا را بررسی می‌کند، ولی نمی‌تواند امضای تازه بسازد. پس اگر کسی گواهی جعلی بسازد یا کلید گواهی را عوض کند، گوشی طرف مقابل آن را رد می‌کند.

۴-۴. تابع هش: اثر انگشت داده

تابع هش از هر داده‌ای، کوچک یا بزرگ، یک عدد کوتاه با طول ثابت می‌سازد. اگر یک بیت از داده عوض شود، نتیجه کاملاً فرق می‌کند، و از نتیجه نمی‌شود به داده رسید. هم‌رسان از هش برای شناسهٔ کلیدها، شناسهٔ مرجع، کد دستگاه و شناختن درخواست‌های تکراری استفاده می‌کند (SHA-256 و BLAKE3).

۴-۵. کامپیوتر کوانتومی و رمزنگاری «پساکوانتومی»

رمزنگاری نامتقارنی که امروز همه جا هست (مثل RSA و منحنی‌های بیضوی، از جمله X25519) بر مسائلی ریاضی تکیه دارد که برای کامپیوترهای معمولی تقریباً حل‌نشدنی‌اند. یک کامپیوتر کوانتومی به اندازهٔ کافی بزرگ آن‌ها را سریع حل می‌کند. چنین کامپیوتری

هنوز ساخته نشده، اما خطر واقعی امروز این است: کسی پیامک‌های رمز را همین حالا ضبط کند و چند سال بعد، وقتی کامپیوتر کوانتومی آمد، بازشان کند. پیامک‌ها از مسیر اپراتور می‌گذرند و ضبط کردنشان کار سختی نیست.

الگوریتم‌های «پساکوانتومی» بر مسائل ریاضی دیگری تکیه دارند که در برابر کامپیوتر کوانتومی هم سخت می‌مانند. مؤسسهٔ استاندارد آمریکا (NIST) در سال ۲۰۲۴، پس از هشت سال مسابقه و بررسی عمومی، این الگوریتم‌ها را استاندارد کرد. هم‌رسان از آن‌ها ML-KEM را برای توافق کلید به کار می‌برد. کلید مرجع یک نیمهٔ ML-DSA (امضای پساکوانتومی) هم دارد که امروز چیزی را امضا نمی‌کند (بخش ۵).

۶-۴. چرا «ترکیبی»؟

الگوریتم‌های پساکوانتومی جدیدند و هنوز آن‌قدر سابقه ندارند که مطمئن باشیم هیچ ضعف ریاضی یا خطای پیاده‌سازی در آن‌ها پیدا نمی‌شود. الگوریتم‌های کلاسیک برعکس، سال‌ها آزموده شده‌اند اما در برابر کامپیوتر کوانتومی آسیب‌پذیرند. هم‌رسان کلید هر کانال ارتقایافته را از **هر دو** می‌سازد: از راز X25519 و از راز ML-KEM. برای خواندن پیام، مهاجم باید هر دو را بشکند. این همان رویکرد سیگنال، کروم و iMessage است.

۵. الگوریتم‌هایی که به کار رفته و چرا

هیچ الگوریتمی برای هم‌رسان اختراع نشده است. در رمزنگاری، الگوریتم ساخت خودمان تقریباً همیشه ضعیف‌تر از الگوریتم‌های استانداردی است که سال‌ها زیر ذره‌بین متخصصان دنیا بوده‌اند. همهٔ الگوریتم‌ها استاندارد هستند و پیاده‌سازی‌شان از کتابخانهٔ متن‌باز و شناخته‌شدهٔ Bouncy Castle (نسخهٔ ۱٫۸۶) و کتابخانه‌های خود اندروید است. همه با بردارهای آزمون رسمی NIST و RFC آزموده شده‌اند.

الگوریتم	نوع	در هم‌رسان کجا	چرا این
ML-KEM-768 FIPS 203	نامتقارن، پساکوانتومی	ارتقای پساکوانتومی کانال امن در پس‌زمینه (بخش ۶-۲)؛ مهروموم کردن رخدادهای دفترچهٔ مخفی	استاندارد پساکوانتومی NIST برای توافق کلید. سطح ۷۶۸ امنیتی هم‌ارز AES-192 دارد و کلید عمومی‌اش (۱۱۸۴ بایت) در چند پیامک جا می‌شود.
X25519 RFC 7748	نامتقارن، کلاسیک	به‌تنهایی در کانال امن ۴ تکه‌ای (سه ترکیب، به سبک Noise XX)؛ کنار ML-KEM در ارتقای پساکوانتومی و مهروموم دفترچهٔ مخفی	نیمهٔ کلاسیک طرح ترکیبی. سال‌ها در TLS، سیگنال و SSH به کار رفته و کلیدش فقط ۳۲ بایت است.
Ed25519 RFC 8032	امضا، کلاسیک	امضای مرجع روی گواهی هر عضو	سریع، کوتاه (۶۴ بایت) و بسیار آزموده. گواهی در هر کانال تازه با پیامک فرستاده می‌شود؛ امضای پساکوانتومی ML-DSA (۳۳۰۹ بایت) آن را به حدود ۳۰ تکه می‌رساند. به تصمیم مالک پروژه گواهی فقط با Ed25519 امضا می‌شود (بخش ۱۷).
ML-DSA-65 FIPS 204	امضا، پساکوانتومی	نیمهٔ دوم کلید عمومی مرجع؛ امروز چیزی را امضا نمی‌کند	جزء شناسهٔ مرجع مانده است تا اگر روزی امضای پساکوانتومی لازم شد، مرجع و کلید عمومی‌اش داخل برنامه عوض نشوند.
AES-256-GCM	متقارن	رمز کردن متن هر پیام، فایل کلید، فایل مرجع و کلید بخش امن	استاندارد جهانی رمز متقارن. حالت GCM هم رمز می‌کند و هم هر دستکاری را تشخیص می‌دهد: اگر یک بیت پیام در راه عوض شود، گیرنده آن را رد می‌کند. کلید ۲۵۶ بیتی در برابر کامپیوتر کوانتومی هم امن می‌ماند.
HKDF-SHA256 RFC 5869	ساخت کلید	کلید جلسه از رازهای مشترک؛ کلید هر عضو از seed مرجع	روش استاندارد برای ساختن کلیدهای جدا و مستقل از یک یا چند راز.
HMAC-SHA256	زنجیرهٔ کلید	کلید جدا برای هر پیام (ratchet)؛ برچسب شماره‌های مخفی	کلید هر پیام از کلید قبلی ساخته می‌شود و راه برگشت ندارد. اگر کلید امروز لو برود، پیام‌های دیروز باز نمی‌شوند.
SHA-256	هش	شناسهٔ کلید عضو، شناسهٔ مرجع، کد کنترل متن پوششی، شناختن درخواست کانال امنِ تکراری	استانداردترین تابع هش.

Argon2id RFC 9106	تبدیل رمز به کلید	باز کردن فایل کلید و فایل مرجع	رمزی که آدم‌ها انتخاب می‌کنند کوتاه است. Argon2id هر حدس را عمداً کند و پرهزینه می‌کند (۶۴ مگابایت حافظه و ۳ دور)، پس حدس زدن میلیون‌ها رمز با کارت گرافیک عملاً ممکن نیست. برندهٔ مسابقهٔ جهانی رمزهای عبور (۲۰۱۵).
PBKDF2-HMAC-SHA256	تبدیل رمز به کلید	کلید بخش امن از رمز ۶ رقمی بخش امن	۲۱۰٬۰۰۰ دور، مطابق توصیهٔ OWASP. جلوی حدس زدن را بیشتر کلید سخت‌افزاری Keystore و سقف تلاش می‌گیرند؛ PBKDF2 فقط هر حدس روی خود گوشی را گران می‌کند.
BLAKE3	هش	کد دستگاه و کد فعال‌سازی	سازگاری با برنامهٔ ویندوزی موجود منتور (بخش ۳).
SQLCipher	پایگاه‌دادهٔ رمزشده	همهٔ محتوای بخش امن	نسخهٔ رمزشدهٔ SQLite با AES-256. پایگاه‌داده روی دیسک همیشه رمز است.
Android Keystore TEE / StrongBox	نگهداری سخت‌افزاری کلید	لایهٔ دوم قفل بخش امن؛ نسخهٔ اثر انگشتی کلید بخش امن؛ کلید برچسب‌های دفترچهٔ مخفی	کلیدی که داخل تراشهٔ امن گوشی ساخته می‌شود هرگز بیرون نمی‌آید. حتی با کپی کامل حافظهٔ گوشی هم نمی‌شود آن را برداشت.

۶. مسیر یک پیام رمز از نوشتن تا خوانده شدن

فرض کنید علی (گوشی اول) می‌خواهد به رضا (گوشی دوم) پیام رمز بفرستد و هر دو فایل کلیدشان را از مرجع سازمان گرفته‌اند.

۶-۱. کلید هر نفر

هر عضو یک جفت‌کلید بلندمدت دارد که فقط از «فایل کلید» خودش به دستش می‌رسد (بخش ۹):

- **کلید خصوصی (۹۷ بایت):** ترکیب ML-KEM-768 و X25519. فقط روی گوشی خود عضو و داخل بخش امن نگه‌داری می‌شود.
- **کلید عمومی:** نیمهٔ X25519 آن (۳۲ بایت) داخل گواهی عضو است. نیمهٔ ML-KEM-768 (۱۱۸۴ بایت) جایی از پیش فرستاده نمی‌شود؛ فقط در ارتقای پساکوانتومی، روی کانالی که از قبل رمز است، به طرف مقابل می‌رسد.
- **گواهی عضو (۱۰۳ بایت):** امضای مرجع روی «شمارهٔ همراه || نسل || کلید X25519» همین عضو (بخش ۹-۳). گوشی آن را در کانال امن برای طرف مقابل می‌فرستد، پس طرف مقابل لازم نیست از پیش چیزی از او داشته باشد.
- **شناسهٔ کلید (۸ بایت):** ۸ بایت اول هش SHA-256 روی یک برچسب ثابت و کلید X25519 عضو. بسته‌ها و گروه‌ها عضو را با همین شناسه می‌شناسند، نه با شمارهٔ تلفن. به همین دلیل اگر کسی از سیم‌کارت دیگرش جواب بدهد، باز هم درست شناخته می‌شود.

۶-۲. کانال امن: یک بار برای هر دو نفر

علی در «گفتگوی رمز» رضا را از مخاطبین انتخاب می‌کند یا شماره‌اش را می‌نویسد. بار اولی که پیام می‌فرستد، برنامه پیش از پیام یک «کانال امن» می‌سازد. علی لازم نیست از پیش کلید رضا را داشته باشد: کافی است شمارهٔ همراهش را بداند و فایل هر دو را یک مرجع صادر کرده باشد.

۱. درخواست از علی (۲ تکه)
گوشی علی یک کلید موقت X25519 می‌سازد و آن را همراه گواهی خودش می‌فرستد: ۱۳۸ بایت، یعنی ۲ تکه پیامک. درخواست نام گیرنده را ندارد؛ هر کس صاحب آن شماره باشد و کلید سازمانی داشته باشد جواب می‌دهد و گواهی‌اش بررسی می‌شود.

۲. پاسخ خودکار رضا (۲ تکه)
گوشی رضا اول امضای مرجع روی گواهی علی را با کلیدهای مرجعی که داخل برنامه است بررسی می‌کند. بعد، بدون دخالت او، با کلید موقت و گواهی خودش و یک کد تأیید جواب می‌دهد: ۱۵۴ بایت، ۲ تکه. رضا هیچ اعلانی برای این بسته نمی‌بیند. علی هم گواهی رضا را بررسی می‌کند.

۳. کلید مشترک
هر دو گوشی از ۳ ترکیب X25519 (موقت با موقت، موقت علی با کلید رضا، کلید علی با موقت رضا) و کل گفتگوی دو بسته، با HKDF کلید جلسه را می‌سازند (الگوی Noise XX). هویت هر دو طرف بدون امضای جداگانه تأیید می‌شود و کلیدهای موقت «محرمانگی پیشرو» می‌دهند. این مرحله هنوز پساکوانتومی نیست.

۴. ارسال پیام
پیامی که در صف بود فرستاده می‌شود. از آن به بعد هر پیام فقط یک پیامک است. در آزمون ۱۴۰۵/۰۷/۲۹، بعد از زدن «دوباره تلاش» پیام در چند ثانیه رسید.

۵. ارتقای پساکوانتومی، بی‌صدا در پس‌زمینه (۲۲ تکه)
پشت پیام‌های کاربر، گوشی علی کلید عمومی ML-KEM-768 خودش را روی همین کانال می‌فرستد (۱۱ تکه). گوشی رضا با آن یک راز تازه می‌سازد و جواب می‌دهد (۱۰ تکه). هر دو از «راز کانال || راز ML-KEM» یک جلسهٔ تازه می‌سازند و علی با یک بستهٔ ۱ تکه‌ای تأیید می‌کند. جلسهٔ تازه امن است اگر هر کدام از دو روش امن باشد. در آزمون، ارتقا کمتر از یک دقیقه بعد از پیام اول کامل شد. **کاربر چیزی از ارتقا نمی‌بیند:** عنوان گفتگو همیشه فقط «رمزشده» است (تصمیم مالک پروژه).

جزئیاتی که کانال را در شبکهٔ واقعی سالم نگه می‌دارد:

- **جلسه‌های در انتظار ارتقا:** رضا جلسهٔ ارتقایافته را تا وقتی از علی رویش پیامی نشنیده فقط نگه می‌دارد. پیشنهادهای ارتقا ممکن است جابه‌جا برسند (در آزمون، یکی ده‌ها دقیقه در شبکه ماند)، پس رضا **دو جلسهٔ آخر** را نگه می‌دارد و وقتی علی روی یکی پیام داد، بقیه را پاک می‌کند. پیش از این اصلاح، پیشنهاد دیررسیده جلسه‌ای را پاک می‌کرد که علی از آن استفاده می‌کرد (بخش ۱۶).
- **ارتقای گم‌شده:** اگر پیشنهاد یا جوابش گم شود، دو طرف روی جلسهٔ کلاسیک می‌مانند و پیام‌ها رد و بدل می‌شوند. علی پیشنهاد را دوباره می‌فرستد: اگر ارسالش ناموفق بوده، با پیام بعدی؛ اگر از آن به بعد از رضا پیامی رسیده، ۲ دقیقه بعد؛ وگرنه بعد از ۳۰ دقیقه.
- **درخواست بی‌پاسخ:** اگر پیامک درخواست از گوشی علی بیرون نرود، فوراً پیام «پیامک درخواست کانال امن ارسال نشد...» و دکمهٔ «دوباره تلاش» می‌آید. اگر رفت ولی ۲ دقیقه جوابی نیامد، پیام «پاسخی از گوشی مقابل نرسیده...» و همان دکمه. پیام‌ها در صف می‌مانند. درخواست بی‌پاسخ بعد از ۱۵ دقیقه با پیام بعدی یا باز شدن گفتگو هم خودکار تکرار می‌شود.
- **درخواست هم‌زمان:** اگر هر دو نفر هم‌زمان کانال بسازند، درخواست با شناسهٔ کلید کوچک‌تر برنده می‌شود.
- **درخواست تکراری:** برنامه هیچ درخواستی را دو بار نمی‌فرستد؛ تکرار همیشه یک درخواست تازه است. پس گوشی اثر انگشت (SHA-256) هر درخواستی را که جواب داده نگه می‌دارد و به درخواستی که قبلاً دیده جواب نمی‌دهد. این جلوی کسی را می‌گیرد که یک درخواست ضبط‌شده را دوباره بفرستد؛ جواب دادن به آن کانالی می‌ساخت که فقط یک طرف داشت.
- **شماره‌ای که هم‌رسان ندارد:** فقط ۲ پیامک نامفهوم برای هر تلاش می‌گیرد و پیام کاربر هرگز برایش فرستاده نمی‌شود. این در آزمون ۱۴۰۵/۰۷/۲۹ با یک شمارهٔ بی‌هم‌رسان آزموده شد.

۶-۳. کلید جدا برای هر پیام

کلید جلسه مستقیم برای رمز کردن پیام به کار نمی‌رود. برای هر جهت (علی به رضا و رضا به علی) یک زنجیرهٔ کلید ساخته می‌شود. هر پیام کلید خودش را از حلقهٔ فعلی زنجیره می‌گیرد و زنجیره یک قدم جلو می‌رود (با HMAC-SHA256). از حلقهٔ جدید نمی‌توان به حلقه‌های قبلی رسید. پس:

- هیچ دو پیامی با یک کلید رمز نمی‌شوند.
- کلیدها برای هر مخاطب هم جدا هستند و هر جفت آدم زنجیرهٔ خودش را دارد.
- پیامکی که دیرتر یا جابه‌جا برسد (تا ۱۰۰۰ پیام جلوتر) درست خوانده می‌شود. پیامکی که اپراتور دو بار تحویل دهد یک بار ثبت می‌شود و پیامک دستکاری‌شده رد می‌شود.
- وضعیت زنجیره همیشه **پیش از** ارسال پیامک ذخیره می‌شود. حتی اگر برنامه وسط کار بسته شود، هیچ کلیدی دو بار مصرف نمی‌شود.

۶-۴. شکل بستهٔ پیام

بخش	محتوا
بیرون بسته (آشکار)	یک بایت نسخه و نوع بسته؛ شناسهٔ جلسه (۲ بایت)؛ شمارهٔ پیام. این‌ها رمز نیستند، اما در برابر دستکاری محافظت می‌شوند.
داخل بسته (رمزشده)	نوع محتوا، پرچم‌ها (حذف پس از دیدن، پیام گروهی، پیام زمان‌دار)، شناسهٔ گروه و مدت زمان‌دار در صورت وجود، و خود متن.
انتهای بسته	برچسب ۱۶ بایتی GCM که هر دستکاری را آشکار می‌کند.
متن فارسی	یک جدول کد فشرده هر حرف فارسی را ۱ بایت می‌کند (در UTF-8 هر حرف ۲ بایت است). پس یک پیامک رمز تا حدود ۹۶ حرف فارسی جا می‌گیرد، در حالی که پیامک فارسی عادی ۷۰ حرف جا دارد.

بستهٔ نهایی با Base64 به حروف و ارقام لاتین تبدیل می‌شود و `#E:` جلویش می‌آید. چون فقط حروف لاتین دارد، هر پیامک ۱۶۰ نویسه جا دارد. این قالب با یک «بردار طلایی» قفل شده است: یک پیام نمونهٔ ثابت در آزمون‌ها که اگر کسی قالب را ناخواسته عوض کند، آزمون شکست می‌خورد. هر تغییر عمدی در قالب، شمارهٔ نسخهٔ پروتکل را بالا می‌برد.

۵-۶. در گوشی گیرنده

- اگر بخش امن قفل باشد، برنامه متن رمزشده را (نه متن اصلی) همراه شمارهٔ فرستنده و زمان در یک صف موقت می‌گذارد و فقط اعلان «پیام رمز جدید» نشان می‌دهد، بدون نام فرستنده و بدون متن.
- بسته‌های کنترلی (کانال امن، ارتقا، «دیده شد»، مشخصات گروه) اعلانی نمی‌سازند.
- با باز شدن بخش امن، صف خوانده و پیام‌ها رمزگشایی می‌شوند. بسته‌ای که هنوز قابل خواندن نیست، مثلاً پیامی که زودتر از پاسخ کانال امن رسیده، تا ۷ روز نگه داشته می‌شود.
- وقتی رضا گفتگو را باز می‌کند، برنامه خودکار یک رسید «دیده شد» برای علی می‌فرستد. این رسید هم رمز است و یک پیامک هزینه دارد و از منوی «پیام‌های رمز» قابل خاموش کردن است.

آنچه فراهم نیست:

- **پیش از ارتقا:** پیام‌هایی که پیش از تمام شدن ارتقا رفته‌اند (معمولاً پیام اول و هر پیامی در همان چند ده ثانیه) فقط با X25519 محافظت می‌شوند. مهاجمی که آن چند پیامک را امروز ضبط کند و روزی کامپیوتر کوانتومی داشته باشد، می‌تواند همان‌ها را باز کند. این هزینهٔ آگاهانهٔ «اولین تماس با ۴ تکه» است. چون عنوان گفتگو وضعیت ارتقا را نشان نمی‌دهد، کاربر نمی‌تواند برای پیام حساس منتظر تمام شدن آن بماند.
- **سرقت هم‌زمان کلیدها:** اگر روزی کلیدهای بلندمدت هر دو طرف هم‌زمان دزدیده شوند و کامپیوتر کوانتومی هم در کار باشد، پیام‌های ضبط‌شدهٔ قبلی در خطرند. محافظت پساکوانتومی در برابر این حالت حدود ۲۰ پیامک به هر کانال اضافه می‌کند. محافظت کلاسیک همین حالت با کلیدهای موقت X25519 فراهم است.

۷. اپراتور و برنامه‌های دیگر چه می‌بینند

پیام رمز هم‌رسان یک پیامک معمولی است و از همان مسیر همیشگی اپراتور می‌گذرد. پس سؤال طبیعی این است که در این مسیر دقیقاً چه دیده می‌شود.

۷-۱. اپراتور

اپراتور (و هر کسی که به سامانهٔ پیامک اپراتور یا مسیر رادیویی دسترسی داشته باشد) متنی شبیه این می‌بیند:

```
#E:EYVVACsmdwrONv35kouv+hNaZbK6ioamtIBogDRjb9nmdrGXhRipY2LMQicQbSC2
```

این یک پیامک واقعی هم‌رسان است (همان «بردار طلایی» آزمون‌ها). هیچ کلمه‌ای از متن اصلی، هیچ اشاره‌ای به اینکه پیام فارسی بوده و هیچ نشانه‌ای از نوع پیام (عادی، زمان‌دار، گروهی یا «حذف پس از دیدن») در آن نیست.

اپراتور نمی‌تواند	اپراتور می‌تواند
• متن پیام را بخواند، حتی اگر همهٔ پیامک‌ها را سال‌ها نگه دارد • پیام را بدون اینکه گیرنده بفهمد تغییر دهد (پیام دستکاری‌شده رد می‌شود) • پیام جعلی به نام یکی از اعضا بسازد • بفهمد کدام پیام زمان‌دار، گروهی یا «حذف پس از دیدن» بوده	• ببیند چه شماره‌ای به چه شماره‌ای، کی و چند پیامک فرستاده (این اطلاعات جزو خود سامانهٔ پیامک است و هیچ برنامه‌ای نمی‌تواند پنهانش کند) • از شکل `#E:` بفهمد که این پیامک یک پیام رمز است (در نسخهٔ سازمانی «متن پوششی» همین را هم پنهان می‌کند) • پیامک را دیر برساند یا نرساند. در آزمون‌ها یک پیامک ۱۷ دقیقه و یک پیشنهاد ارتقا ده‌ها دقیقه در شبکه ماند و بعد رسید.

۷-۲. برنامه‌های دیگر گوشی (مثل Google Messages)

- **اگر هم‌رسان برنامهٔ پیش‌فرض پیامک باشد** (که موقع نصب درخواستش می‌کند): پیام رمز اصلاً در حافظهٔ پیامک اندروید (`content://sms`) نوشته نمی‌شود، نه موقع ارسال و نه موقع دریافت. پس برنامه‌های دیگر، پشتیبان‌گیری گوگل و برنامه‌هایی که اجازهٔ خواندن پیامک دارند، هیچ اثری از آن نمی‌بینند. این در آزمون ۱۴۰۵/۰۷/۲۹ روی هر دو گوشی بررسی شد.
- **اگر هم‌رسان پیش‌فرض نباشد:** اندروید خودش پیامک دریافتی را ذخیره می‌کند. هم‌رسان باز هم آن را می‌گیرد و رمزگشایی می‌کند، اما برنامهٔ پیامک دیگر همان رشتهٔ `#E:…` را مثل یک پیامک عجیب نشان می‌دهد. متن اصلی دیده نمی‌شود، ولی آمدن پیام رمز آشکار است. صفحهٔ «کنترل امنیت سامانه» در این حالت هشدار می‌دهد.
- **اعلان‌ها:** اعلان پیام رمز فقط می‌گوید «پیام رمز جدید · برای خواندن، بخش امن را باز کنید». روی صفحهٔ قفل گوشی، ساعت هوشمند یا برنامه‌هایی که اعلان‌ها را می‌خوانند چیزی لو نمی‌رود.

۷-۳. متن پوششی (فقط نسخهٔ سازمانی)

در نسخهٔ سازمانی می‌توان پیام رمز را به‌جای `#E:…` به شکل یک متن معمولی فرستاد. هر بایت بستهٔ رمزشده با یکی از ۲۵۶ کلمهٔ یک فهرست ثابت جایگزین می‌شود، ۲ کلمهٔ کنترلی در آخر می‌آید و بعد از هر ۹ کلمه یک نقطه گذاشته می‌شود. همان پیام نمونهٔ بالا در دو حالت متن پوششی:

> معلم کوتاه اتاق خانه مدیر کار سبز شهر چند. هفته کلید قایق فیلم سریع امید بندر پدر شیر. انار لبخند نمره تند نزدیک پا گربه زیبا بادام. زیبا ظهر انگور لیوان دید دوید رنگ مهر قصه. کوتاه همسایه گوش انگور پرتقال همه آسمان شغل کلاس. قاشق کشتی جواب وسط دوچرخه.

```
problem decision war time study story role world truth. service plate milk society arm phone tea part mor
ning. boy practice news road son need land wife music. wife head education death bridge wind development
picture record. decision system situation education force evidence community fact country. college home d
octor source water.
```

- این متن معنای جمله‌ای ندارد، اما برخلاف `#E:…` در نگاه اول و برای فیلترهای خودکار شبیه پیامک عادی است.
- گیرنده کلید جداگانه‌ای لازم ندارد: برنامه تشخیص می‌دهد که همهٔ کلمه‌ها از فهرست‌اند و کد کنترلی درست است، متن را به بستهٔ اصلی برمی‌گرداند و رمزگشایی می‌کند. امنیت پیام همان امنیت `#E:` است؛ متن پوششی فقط شکل ظاهری را عوض می‌کند.
- هزینه: هر بایت یک کلمه می‌شود، پس یک پیام کوتاه ۲ تا ۴ پیامک می‌شود. برای همین فقط برای پیام‌ها و رسیدها به کار می‌رود، نه برای ساختن کانال امن.

۸. بخش امن

«بخش امن» قسمتی از برنامه است که همهٔ محتوای محرمانه داخلش است: پیام‌های رمز، گروه‌های رمز، فایل کلید واردشده، دفترچهٔ مخفی، تماس‌ها و پیامک‌های مخفی و عکس‌های ورود ناموفق. بیرون از آن، برنامه مثل یک پیام‌رسان معمولی است.

- **آیکون قفل:** بالای همهٔ زبانه‌ها یک آیکون قفل هست (فقط در نسخه‌های امن). قفل بسته یعنی هیچ نشانه‌ای از محتوای امن روی صفحه نیست، حتی ردیف‌های «پیام‌های رمز» و «دفترچه مخفی».
- **رمز جداگانه:** بخش امن رمز ۶ رقمی خودش را دارد که با رمز برنامه فرق دارد (برنامه رمز یکسان را نمی‌پذیرد). رمز برنامه ۴ رقمی است و فقط در برنامه را باز می‌کند. هیچ کاری با رمز برنامه (گذاشتن، عوض کردن، برداشتن، بازیابی) به بخش امن دست نمی‌زند.
- **سقف تلاش جداگانه:** بعد از ۵ رمز اشتباه، ۳۰ ثانیه صبر و هر بار دو برابر تا ۳۰ دقیقه. قفل شدن یکی از دو رمز، دیگری را قفل نمی‌کند. رمز اشتباه بخش امن هم برای «عکس از ورود ناموفق» حساب می‌شود.
- **نحوهٔ قفل:** محتوا در یک پایگاه‌دادهٔ جدای رمزشده (SQLCipher) است. کلیدش ۳۲ بایت تصادفی است که دو بار قفل شده: یک بار با کلیدی که از رمز بخش امن ساخته می‌شود (PBKDF2، ۲۱۰,۰۰۰ دور، سپس AES-256-GCM) و یک بار با کلید سخت‌افزاری Android Keystore که از تراشهٔ امن گوشی بیرون نمی‌آید. پس کپی فایل‌ها روی دستگاه دیگر به هیچ دردی نمی‌خورد: حدس زدن رمز فقط روی خود گوشی و با سقف تلاش ممکن است.
- **اثر انگشت:** اگر روشن شود، یک نسخهٔ دوم از کلید پایگاه‌داده با کلیدی در Keystore قفل می‌شود که فقط یک اثر انگشت «قوی» (Class 3) برای هر بار استفاده بازش می‌کند. با ثبت اثر انگشت تازه در گوشی، اندروید آن کلید را از بین می‌برد و گزینه خاموش می‌شود. رمز صفحهٔ خود گوشی هرگز جای رمز بخش امن را نمی‌گیرد.
- **قاعدهٔ اصلی:** هیچ چیز محرمانه‌ای در پایگاه‌دادهٔ اصلی برنامه، حافظهٔ پیامک اندروید یا سوابق تماس اندروید نوشته نمی‌شود.
- **قفل خودکار:** با خروج از برنامه، بخش امن فوراً بسته می‌شود. بعد از وارد کردن دوبارهٔ رمز، همان صفحه با محتوایش برمی‌گردد.
- **جلوگیری از اسکرین‌شات:** وقتی بخش امن باز است، اسکرین‌شات و فیلم‌برداری سیاه درمی‌آید و تصویر برنامه در فهرست برنامه‌های اخیر خالی است (FLAG_SECURE). متن پیام‌های رمز قابل انتخاب و کپی نیست و صفحه‌کلید اجازهٔ یادگیری کلمات آن را ندارد.
- **فراموشی رمز بخش امن:** محتوا از دست می‌رود. «رمز بخش امن را فراموش کرده‌ام» بخش را پاک و از نو می‌سازد و رمز برنامه دست نمی‌خورد. هر راه بازیابی محتوا در عمل یک در پشتی است که دیگران هم می‌توانند از آن استفاده کنند.

۹. بانک کلید، فایل کلید و گواهی عضو

برای اینکه دو نفر پیام رمز رد و بدل کنند، هر کدام باید مطمئن شود کلید طرف مقابل واقعاً مال همان شماره است. در هم‌رسان این اطمینان از **امضای مرجع** می‌آید، نه از فهرستی که روی گوشی باشد. «بانک کلید» جایی در برنامه است که فایل کلید خود کاربر در آن نگه داشته می‌شود: تنظیمات ← «بانک کلید» (وقتی بخش امن باز است).

۹-۱. اصطلاحات

اصطلاح	یعنی چه و کجا به کار می‌رود
مرجع کلید (authority)	شخص یا واحدی در سازمان که کلید اعضا را صادر می‌کند. مرجع با «پنل صدور هم‌رسان» کار می‌کند و یک «کلید امضا» دارد که فقط نزد خودش است. نقشش شبیه دفتر صدور کارت شناسایی است.
کلید عمومی مرجع	نیمهٔ عمومی کلید مرجع (۱۹۸۵ بایت: ML-DSA-65 و Ed25519). داخل خود برنامه قرار گرفته است و برنامه با آن امضای مرجع روی گواهی‌ها را بررسی می‌کند. محرمانه نیست، چون با آن فقط می‌شود امضا را بررسی کرد. کلید فعلی برنامه شناسهٔ `7fda025a5a997b93` دارد.
فایل کلید (.hkb)	فایلی که مرجع برای هر عضو جداگانه می‌سازد: کلید خصوصی همان عضو و گواهی عضو او. هیچ چیز دیگری در آن نیست. با یک رمز ۲۰ نویسه‌ای قفل است. تنها راه رسیدن کلید به گوشی همین فایل است.
رمز فایل کلید	۲۰ نویسه از ۳۲ حرف و رقم بدون ابهام (بدون O/0 و I/1)، در ۵ گروه چهارتایی؛ ۱۰۰ بیت تصادف. هنگام وارد کردن، حروف کوچک، فاصله و خط تیره اهمیتی ندارد. رمز باید از راهی جدا از خود فایل به عضو برسد.
نسل (generation)	عددی کنار هر عضو در فهرست مرجع (۰ تا ۲۵۵). با «گوشی گم شد»، نسل یکی زیاد می‌شود تا عضو کلید تازه بگیرد. نسل داخل گواهی هم هست و گوشی، گواهی‌ای با نسل کمتر از آنچه برای همان شماره دیده، نمی‌پذیرد.
گواهی عضو	امضای مرجع روی شمارهٔ همراه، نسل و کلید X25519 یک عضو (بخش ۹-۳).

۹-۲. ساختار دقیق فایل کلید (۲۶۱ بایت)

بخش	اندازه	توضیح
نشانه	۵ بایت	متن `HMRKB` . برنامه از آن می‌فهمد این فایل کلید هم‌رسان است.
نسخهٔ قالب	۱ بایت	`1`
هزینهٔ Argon2id	۶ بایت	تعداد دور (۳)، حافظه (۶۴ مگابایت) و موازی‌سازی (۱). برنامه پیش از شروع بررسی می‌کند که این اعداد از سقف مجاز بیشتر نباشد، تا یک فایل مخرب نتواند گوشی را از کار بیندازد.
نمک (salt)	۱۶ بایت	عدد تصادفی که باعث می‌شود رمز یکسان در دو فایل، کلید یکسان نسازد.
nonce	۱۲ بایت	عدد تصادفی AES-GCM
بدنهٔ رمزشده	۲۲۱ بایت	با AES-256-GCM و کلیدی که Argon2id از رمز فایل می‌سازد رمز شده است (۲۰۵ بایت داده و ۱۶ بایت برچسب). سرآیند هم جزو داده‌های محافظت‌شده است و اگر یک بایتش عوض شود، فایل باز نمی‌شود.
داخل بدنه: قالب	۱ بایت	`1`
داخل بدنه: کلید عضو	۲ + ۹۷ بایت	کلید خصوصی ترکیبی عضو (ML-KEM-768 و X25519).

داخل بدنه: گواهی عضو	۲ + ۱۰۳ بایت	بخش ۹-۳.

نام فایل اهمیتی ندارد. پنل آن را به شکل `<شماره>.hkb` می‌سازد، مثل `09127763032.hkb` .

شرایط پذیرفته شدن فایل روی گوشی:

- فایل باید روی گوشی باشد، هر جا: دانلودها، فلش، کارت حافظه یا فایلی که از پیام‌رسان ذخیره شده. برنامه با پنجرهٔ انتخاب فایل خود اندروید آن را می‌گیرد و به هیچ مجوز اضافه‌ای نیاز ندارد.
- رمز باید درست باشد. رمز اشتباه با پیام «رمز فایل کلید اشتباه است» رد می‌شود و هیچ چیزی تغییر نمی‌کند.
- امضای گواهی باید با یکی از کلیدهای مرجعی که داخل برنامه است بخواند؛ وگرنه «این فایل را مرجعی امضا کرده که این برنامه به آن اعتماد ندارد».
- کلیدی که گواهی نام می‌برد باید دقیقاً همان کلید خصوصی داخل فایل باشد؛ وگرنه «محتوای فایل کلید معتبر نیست».
- برای هر مرجع یک کلید روی گوشی نگه داشته می‌شود. فایل تکراری «قبلاً وارد شده است» می‌گیرد؛ کلید نسل تازه‌تر برای همان شماره جای قبلی را می‌گیرد («کلید تازه جای کلید قبلی شما نشست»)؛ نسل قدیمی‌تر رد می‌شود.

بعد از وارد شدن، بانک کلید زیر «کلید شما» شمارهٔ گواهی، نسل و تاریخ ورود را نشان می‌دهد. فایل را می‌شود از گوشی پاک کرد؛ برنامه دیگر به آن نیازی ندارد. وارد کردن یک فایل روی گوشی آزمون حدود یک ثانیه طول کشید (بیشترش Argon2id).

۹-۳. گواهی عضو

مسئله: منتور یادآوری کرد که اگر برای پیام دادن به یک عضو، کلید او باید از پیش در گوشی همه باشد، هر عضو تازه یعنی رساندن فایل تازه به همهٔ اعضا؛ و وقتی اینترنت قطع است و فقط پیامک کار می‌کند، این عملاً ممکن نیست. **راه انتخاب‌شده** (به تصمیم مالک پروژه) گواهی است: هر عضو فقط کلید خودش را دارد، مرجع آن کلید را برای شماره‌اش امضا می‌کند و عضو این امضا را همراه دارد. هیچ فهرستی از اعضا روی هیچ گوشی‌ای نیست.

بخش گواهی	اندازه	توضیح
قالب	۱ بایت	`1`
شمارهٔ همراه	۵ بایت	۱۰ رقم بعد از صفر، دو رقم در هر بایت. فقط شماره‌های `09…` گواهی می‌گیرند؛ پنل گواهی را برای اولین شمارهٔ همراه عضو می‌سازد.
نسل	۱ بایت	۰ تا ۲۵۵.
کلید X25519	۳۲ بایت	نیمهٔ کلاسیک کلید عمومی همین عضو.
امضای Ed25519 مرجع	۶۴ بایت	روی همهٔ بخش‌های بالا به‌علاوهٔ شناسهٔ مرجع. شناسهٔ مرجع فرستاده نمی‌شود؛ گیرنده امضا را با هر کلید مرجعی که داخل برنامه است امتحان می‌کند.

- **بررسی پیش از هر کار:** گواهی رسیده پیش از اینکه چیزی ذخیره یا جوابی فرستاده شود بررسی می‌شود. گفتگو زیر شماره‌ای ثبت می‌شود که خود گواهی می‌گوید، نه شماره‌ای که پیامک از آن آمده.
- **شناسهٔ کلید:** سمت اندروید و سمت فلاتر آن را جداگانه حساب می‌کنند و هر دو با یک بردار آزمون ثابت قفل شده‌اند.
- **چه وقت درخواست فرستاده می‌شود:** فقط وقتی کاربر خودش در یک گفتگوی رمز پیام بفرستد: گفتگویی که با «گفتگوی رمز» (انتخاب از مخاطبین یا شمارهٔ تایپ‌شده) یا دکمهٔ «پیام رمز» مخاطب مخفی باز کرده است. پیامک عادی هیچ‌وقت خودکار به درخواست کانال امن تبدیل نمی‌شود.
- **گوشی گم‌شده:** وقتی گوشی‌ای گواهی نسل تازهٔ یک شماره را ببیند، جلسه‌های قبلی با آن شماره کنار گذاشته می‌شوند و از آن به بعد گواهی نسل قبلی را نمی‌پذیرد.

۹-۴. صدور کلید

روش اصلی «پنل صدور هم‌رسان» (نسخهٔ ۱٫۴، فایل نصب `HamresanPanel-1.4.0.msi`) است که راهنمای جداگانه دارد. پنل کد فعال‌سازی می‌سازد، عضو اضافه می‌کند، «گوشی گم شد»، ویرایش و حذف دارد، تحویل‌ها را در «دفتر صدور» ثبت می‌کند و برگهٔ تحویل چاپی می‌سازد. هر تغییر فقط فایل همان عضو را می‌سازد یا پاک می‌کند و «همه یا هیچ» است: اگر وسط کار خطا پیش بیاید، هیچ فایلی عوض نمی‌شود.

ابزار خط فرمان هم هست (`hamresan-keybank.jar` با `hamresan-keybank.cmd`، به جاوا ۱۱ یا بالاتر نیاز دارد). این ابزار و پنل از همان کد رمزنگاری خود برنامه ساخته شده‌اند، پس هر فایلی که بسازند، برنامه دقیقاً همان را می‌خواند.

#	دستور	کار
۱	`hamresan-keybank init authority.hka`	ساختن مرجع، فقط یک بار. رمزی دست‌کم ۱۲ نویسه‌ای می‌خواهد.
۲	`hamresan-keybank public authority.hka`	چاپ کلید عمومی مرجع (یک خط هگز ۳۹۷۰ نویسه‌ای) که داخل برنامه قرار می‌گیرد.
۳	`hamresan-keybank issue authority.hka roster.csv out`	برای هر عضو `out\<شماره>.hkb` و برای همه یک `out\passwords.csv` می‌سازد. رمز اعضای قبلی در صدور دوباره عوض نمی‌شود.
۴	`hamresan-keybank inspect …`	بررسی یک فایل، اختیاری.
۵	`hamresan-keybank activation <کد دستگاه>`	کد فعال‌سازی یک گوشی؛ به مرجع نیاز ندارد.

- **کلید هر عضو** از اولین شماره و نسلش ساخته می‌شود: HKDF(seed اعضای مرجع، شماره ‖ نسل). پس صدور دوباره همان کلید را می‌دهد و ترتیب شماره‌ها نباید عوض شود.
- چون مرجع کلید همهٔ اعضا را از یک seed می‌سازد، هر زمان می‌تواند کلید هر عضو را بازسازی کند. این صدور دوباره را ساده می‌کند، اما یعنی مرجع در صورت نیاز می‌تواند پیام اعضا را هم بخواند (بخش ۱۷).
- کلیدی که با «گوشی گم شد» کنار گذاشته شد، دیگر ساخته نمی‌شود: پنل نسل بعدی را از دفتر صدور می‌خواند، حتی اگر همان شماره حذف و دوباره اضافه شود.

۹-۵. مرجع آزمایشی و مرجع واقعی

در دوران توسعه یک مرجع آزمایشی وجود داشت. برنامه فقط وقتی به آن اعتماد می‌کند که با یک تنظیم خاص برای توسعه ساخته شده باشد؛ در این حالت بانک کلید نوار قرمز «نسخه آزمایشی» نشان می‌دهد. اسکریپت ساخت نسخهٔ نهایی هر فایل نصبی‌ای را که کلید آزمایشی داشته باشد رد می‌کند. نسخهٔ نهایی فقط فایل‌های مرجع واقعی را قبول می‌کند (بخش ۱۰).

۱۰. پوشهٔ مرجع کلید: `C:\Users\hp\Hamresan-Authority`

این پوشه «دفتر مرجع کلید» این پروژه است. در ۱۴۰۵/۰۷/۲۹، به تصمیم مالک پروژه، مرجع قبلی کنار گذاشته و یک مرجع تازه ساخته شد (شناسهٔ `7fda025a5a997b93`)؛ کلید عمومی‌اش جای مرجع قبلی را در برنامه گرفت و برای گوشی‌های آزمون از نو کلید صادر شد. پوشه عمداً بیرون از مخزن کد است و هیچ‌وقت در git ثبت نشده است، چون کلید خصوصی مرجع در آن است.

فایل	محرمانه؟	چیست و چه کار می‌کند
`authority.hka`	بسیار محرمانه	**کلید خصوصی مرجع.** با نشانهٔ `HMRKA` شروع می‌شود و ساختارش مثل فایل کلید است: سرآیند Argon2id و بدنهٔ AES-256-GCM که با رمز مرجع قفل شده. داخلش سه عدد تصادفی ۳۲ بایتی است: seed امضای ML-DSA، seed امضای Ed25519 و seed اعضا که کلید همهٔ اعضا از آن ساخته می‌شود. هر کس این فایل و رمزش را داشته باشد، برای کل سازمان گواهی صادر می‌کند، عضو جعلی می‌سازد یا کلید هر عضو را بازسازی می‌کند. اگر گم شود، باید مرجع تازه ساخته شود، برنامه با کلید عمومی جدید منتشر شود و برای همه فایل کلید تازه صادر شود.
`authority-password.txt`	بسیار محرمانه	رمز فایل بالا. فقط برای دورهٔ آزمون کنار فایل گذاشته شده. **در استفادهٔ واقعی، رمز مرجع هرگز نباید روی همان رایانه و کنار فایل باشد.**
`authority-public.txt`	عمومی	کلید عمومی مرجع: یک خط هگز ۳۹۷۰ نویسه‌ای (۱۹۸۵ بایت). همین خط داخل برنامه، در فایل `trust_anchors.dart` ، قرار گرفته است.
`roster.csv`	داخلی	فهرست اعضا برای پنل: نام سازمان («سازمان نمونه هم‌رسان») و سه عضو آزمون: «سامسونگ آزمون» با `09034853204` ، «شیائومی آزمون» با `09356455230` و «هواوی آزمون» با `09127763032` . داخل هیچ فایل کلیدی نمی‌رود.
`issued\<شماره>.hkb`	با رمز قفل است	فایل کلید هر عضو. هر کدام روی گوشی همان عضو وارد و بعد از گوشی پاک شده است.
`issued\passwords.csv`	محرمانه	رمز فایل کلید هر عضو. فایل و رمز هر عضو باید از دو راه جدا به دستش برسد.
`issuance-log.csv`	داخلی	دفتر صدور: هر افزودن، ویرایش، کلید تازه، حذف و تحویل با تاریخ. پنل نسل بعدی هر شماره و وضعیت تحویل را از آن می‌خواند.
`backups\`	داخلی	نسخهٔ قبلی `roster.csv` پیش از هر تغییر.
`README-FA.txt`	داخلی	یادداشت فارسی دربارهٔ همین پوشه و اعضای آزمون. بعد از دورهٔ آزمون پاک شود.

توصیه برای استفادهٔ واقعی: این پوشه را به یک رایانهٔ بدون اینترنت منتقل کنید. از `authority.hka` یک پشتیبان روی حافظهٔ جدا بگیرید و در جای امن نگه دارید. `authority-password.txt` و `README-FA.txt` را پاک کنید. بعد از اینکه هر عضو فایلش را وارد کرد، یا رمزش را از `passwords.csv` بردارید یا کل پوشه را رمز کنید.

۱۱. پیام رمز گروهی

پیامک ارسال گروهی واقعی ندارد: اپراتور برای ده گیرنده هم ده پیامک جدا می‌فرستد. پس هم‌رسان پیام گروه را برای هر عضو جداگانه، روی کانال امن دونفرهٔ همان عضو، رمز و ارسال می‌کند. همهٔ ویژگی‌های کانال دونفره، مثل کلید جدا برای هر پیام، برای گروه هم برقرار است.

- **هزینه:** هر پیام به ازای هر گیرنده یک پیامک است. برنامه این را زیر کادر نوشتن نشان می‌دهد.
- **اعضا:** سازنده اعضا را از گفتگوهای رمزش یا با «افزودن از مخاطبین» انتخاب می‌کند. فقط شماره‌های همراه پذیرفته می‌شوند.
- **دو نوع گروه** که سازنده انتخاب می‌کند و بعداً عوض نمی‌شود: «گفتگوی گروهی»، که پاسخ هر عضو به همه می‌رسد، و «اطلاع‌رسانی»، که پاسخ اعضا فقط به سازنده می‌رسد.
- **مشخصات گروه** (نام، نوع، فهرست اعضا) یک بستهٔ رمزشدهٔ جداست که پیش از اولین پیام و بعد از هر تغییر برای اعضا فرستاده می‌شود. فقط مشخصاتی پذیرفته می‌شود که از خود سازنده آمده و از قبلی جدیدتر باشد، پس عضو دیگری نمی‌تواند خودش را مدیر جا بزند.
- **«دیده شد»** فقط به فرستندهٔ همان پیام می‌رود. فرستنده «دیده شده ۲ از ۳» را زیر پیام می‌بیند و با نگه داشتن پیام، وضعیت هر عضو را جدا: در انتظار کانال امن، ارسال‌شده، تحویل‌شده، دیده‌شده یا ناموفق.
- سقف ۱۰۰ عضو است. اولین بار که دو عضو در گروه با هم حرف می‌زنند، کانال امن بینشان خودکار ساخته می‌شود. عضوی که هنوز کانالی با او ساخته نشده، با شناسهٔ کلید صفر در تعریف گروه می‌آید و گیرنده‌ها او را با شماره‌اش پیدا می‌کنند.
- حذف گروه فقط از گوشی خود کاربر است و روی گوشی بقیه می‌ماند.

۱۲. دفترچهٔ تلفن مخفی

گاهی خود اینکه شما با چه کسی در تماس هستید محرمانه است، نه فقط محتوای پیام‌ها. «دفترچه مخفی» برای همین است. مخاطبی که در آن ذخیره شود، هیچ ردی بیرون از بخش امن باقی نمی‌گذارد. او لازم نیست هم‌رسان داشته باشد.

- **دفترچهٔ تلفن:** در دفترچهٔ تلفن اندروید نیست. برنامه‌های دیگری که به مخاطبین دسترسی دارند، مثل واتس‌اپ و تلگرام، آن را نمی‌بینند.
- **تماس‌ها:** اندروید هر تماس را خودش در سوابق تماس ثبت می‌کند و نمی‌شود جلویش را گرفت. هم‌رسان بلافاصله بعد از تماس آن ردیف را رمز می‌کند، به «تماس‌های مخفی» می‌برد و از سوابق اندروید پاک می‌کند. در آزمون ۱۴۰۵/۰۷/۲۹ بعد از سه تماس بی‌پاسخ، سوابق تماس سامسونگ هیچ ردیفی برای آن شماره نداشت.
- **پیامک‌ها، دو نوع و دو جا:** پیام رمز به مخاطب مخفی در گفتگوی رمزشدهٔ او است. پیامک عادی او (رسیده یا فرستاده) در یک گفتگوی جداگانه، زیر ردیف «پیامک‌های رمزنشدهٔ مخفی» در صندوق «پیام‌های رمز». این دو هیچ‌وقت در یک گفتگو قاطی نمی‌شوند و هیچ‌کدام در حافظهٔ پیامک اندروید ثبت نمی‌شوند. صفحهٔ مخاطب برای هر کدام دکمهٔ جدا دارد: «پیام رمز» و «پیامک رمزنشده».
- **وقتی بخش امن قفل است:** تماس ورودی از مخاطب مخفی فقط شماره را نشان می‌دهد، نه نام. تماس بی‌پاسخ فقط می‌گوید «تماس بی‌پاسخ · برای دیدن، بخش امن را باز کنید».
- **سوابق قبلی:** با مخفی شدن یک شماره، پیامک‌ها و تماس‌های قبلی آن هم از سوابق گوشی به بخش امن منتقل می‌شوند. پیام زمان‌بندی‌شده به شمارهٔ مخفی هم بی‌اثر از مسیر امن می‌رود. اگر اپراتور دربارهٔ تماس بی‌پاسخ یک شمارهٔ مخفی پیامک بدهد، آن پیامک هم به بخش امن می‌رود.

- **سازوکار:** وقتی بخش امن قفل است، برنامه کلید آن را ندارد. پس شماره‌های مخفی را فقط به شکل «برچسب» می‌شناسد: هش HMAC با کلیدی که در Android Keystore قفل است. هر اتفاقی که در این مدت بیفتد، با کلید عمومی خود بخش امن (X25519 + ML-KEM-768) مهروموم می‌شود و فقط بعد از باز شدن قفل خوانده می‌شود.

برای اینکه این قابلیت کامل کار کند، هم‌رسان باید برنامهٔ پیش‌فرض پیامک و تلفن باشد. برنامه بعد از ذخیرهٔ اولین مخاطب مخفی این را پیشنهاد می‌دهد.

۱۳. قابلیت‌های امنیتی دیگر

قابلیت	چه می‌کند
دیده شد	وقتی گیرنده گفتگو را باز می‌کند، یک رسید رمزشده برای فرستنده می‌رود و زیر پیام «دیده شد» می‌آید. یک رسید همهٔ پیام‌های تازه را پوشش می‌دهد. از منوی «پیام‌های رمز» قابل خاموش کردن است.
حذف برای هر دو	با نگه داشتن پیام خودتان، پیام از گوشی طرف مقابل هم پاک می‌شود. گیرنده فقط پیامی را پاک می‌کند که واقعاً از همان فرستنده گرفته است. در آزمون، پیام چند ثانیه بعد از گوشی دیگر هم پاک شد.
حذف پس از دیدن	فرستنده پیش از ارسال انتخاب می‌کند. در گوشی گیرنده، پیام بعد از نمایش علامت می‌خورد و با بیرون رفتن از گفتگو پاک می‌شود.
پیام زمان‌دار	۳۰ ثانیه، ۵ دقیقه، ۱ ساعت، ۱ روز یا ۱ هفته. در گوشی گیرنده زمان از لحظهٔ دیدن حساب می‌شود و در گوشی فرستنده از لحظهٔ ارسال. مدت داخل بخش رمزشده است و اپراتور آن را نمی‌بیند.
انتخاب سیم‌کارت	در گوشی دوسیم‌کارته، از منوی «پیام‌های رمز» تعیین می‌شود پیام رمز با کدام سیم‌کارت برود. باید سیمی باشد که شمارهٔ گواهی عضو روی آن است.
کنترل امنیت سامانه	وضعیت امنیتی گوشی را بررسی و به زبان ساده گزارش می‌کند: روت، ابزارهای نفوذ و دستکاری (مثل Frida و Xposed)، امضای رسمی برنامه، شبیه‌ساز، اشکال‌زدایی USB، قفل صفحه، برنامه‌هایی که صفحه را می‌خوانند، تاریخ وصلهٔ امنیتی، رمزنگاری حافظه، محل نگهداری کلید بخش امن (StrongBox یا TEE) و پیش‌فرض بودن هم‌رسان. هر مورد سالم، هشدار یا خطر است.
عکس از ورود ناموفق	اگر روشن باشد، با هر ۳ رمز اشتباه پشت‌سرهم (رمز برنامه یا رمز بخش امن)، برنامه بی‌صدا با دوربین جلو و پشت عکس می‌گیرد. عکس‌ها مهروموم و فقط داخل بخش امن نگه داشته می‌شوند و بعد از ورود موفق گزارش داده می‌شوند. پیش‌فرض خاموش است.
متن پوششی	فقط نسخهٔ سازمانی؛ بخش ۷-۳.
قفل برنامه و تماس (در همهٔ نسخه‌ها)	
قفل خودکار	اگر برنامه بیشتر از مدت انتخابی (فوراً، ۱، ۵ یا ۳۰ دقیقه؛ پیش‌فرض ۱ دقیقه) پشت صحنه بماند، رمز برنامه دوباره خواسته می‌شود. هر بار که برنامه از نو اجرا شود، قفل است.
اثر انگشت یا چهره برای برنامه	به‌جای رمز برنامه؛ پیش‌فرض خاموش. از پنجرهٔ استاندارد اندروید (BiometricPrompt) استفاده می‌کند و رمز صفحهٔ گوشی را به‌جای رمز برنامه نمی‌پذیرد. فقط قفل برنامه را باز می‌کند؛ بخش امن اثر انگشت جداگانه دارد (بخش ۸).
پنهان کردن محتوای اعلان‌ها	پیش‌فرض روشن. وقتی برنامه قفل است، اعلان پیامک و تماس بی‌پاسخ فقط می‌گوید «پیام جدید»: بدون نام، متن، عکس و دکمه.
رمز برای پاسخ به تماس	پیش‌فرض خاموش. اگر روشن باشد، صفحهٔ رمز روی صفحهٔ تماس ورودی می‌آید.
مسدود کردن تماس	رد کردن تماس‌های ناشناس، خارج از مخاطبین، بین‌المللی و پیش‌شماره‌های تبلیغاتی (پیش‌فرض ۰۹۴۲). مخاطبان، شماره‌هایی که در ۷ روز گذشته گرفته شده‌اند و شماره‌های خدماتی هرگز مسدود نمی‌شوند.

۱۴. نقشهٔ استفاده از برنامه، با تصویر

این بخش مسیر کلی کار را با تصویر نشان می‌دهد تا معلوم شود هر قابلیت کجای برنامه است. تصویرها در ۱۴۰۵/۰۷/۲۹ از دو گوشی واقعی با سیم‌کارت و شبکهٔ واقعی گرفته شده‌اند: گوشی اول سامسونگ Galaxy A33 (`09034853204`) و گوشی دوم هواوی ART-L29 (`09127763032`) که همان روز به سازمان اضافه شد، بدون هیچ فایل تازه‌ای برای سامسونگ. صفحه‌های بخش امن در نسخهٔ واقعی سیاه درمی‌آیند؛ فقط برای این عکس‌ها از یک نسخهٔ موقت استفاده شد و بعد نسخهٔ اصلی دوباره نصب شد. از صفحه‌هایی که اطلاعات شخصی داشتند فقط بخش مربوط نگه داشته شده است. راهنمای کاربر همین مسیر را با جزئیات کامل‌تر نشان می‌دهد.

گام ۱. فعال کردن نسخهٔ بین‌سازمانی

در «درباره برنامه»، ردیف «نسخه بین‌سازمانی» کد دستگاه را نشان می‌دهد. کاربر آن را به پشتیبانی می‌دهد و کد فعال‌سازی را وارد می‌کند.



۱ «درباره برنامه»



۲ کد دستگاه: a88129



۳ کد اشتباه رد می‌شود



۴ نسخه فعال شد

گام ۲. ساختن بخش امن با رمز جداگانه

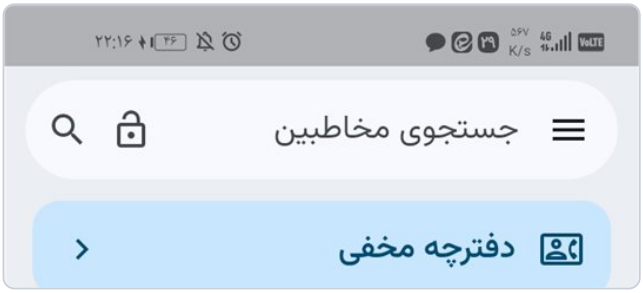
اولین لمس آیکون قفل، بخش امن را با یک رمز ۶ رقمی جدا از رمز برنامه می‌سازد. وقتی قفل باز است، ردیف‌های امن ظاهر می‌شوند.



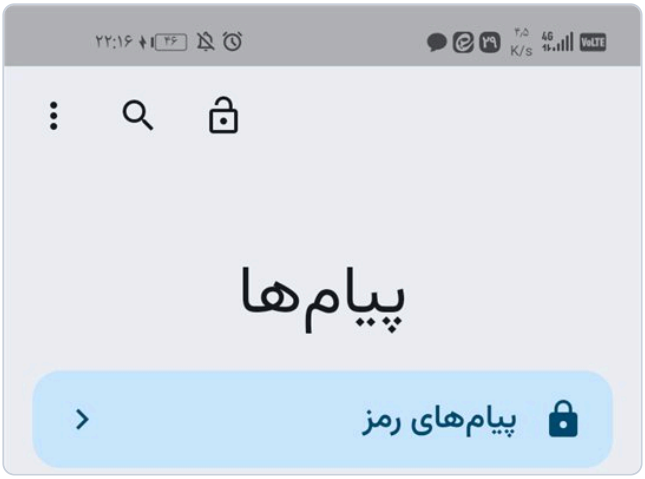
۵ «ساخت بخش امن»



۶ قفل بسته



۷ قفل باز: «دفترچه مخفی»



۸ قفل باز: «پیام‌های رمز»

گام ۳. وارد کردن فایل کلید

تنظیمات ← «بانک کلید» ← «وارد کردن فایل کلید». کاربر فایل ۲۶۱ بایتی را انتخاب و رمز ۲۰ نویسه‌ای‌اش را وارد می‌کند. رمز اشتباه رد می‌شود. بعد از ورود، زیر «کلید شما» شمارهٔ گواهی و نسل کلید دیده می‌شود.



۹ بانک کلید خالی



۱۰ رمز فایل کلید



۱۱ «رمز فایل کلید اشتباه است»



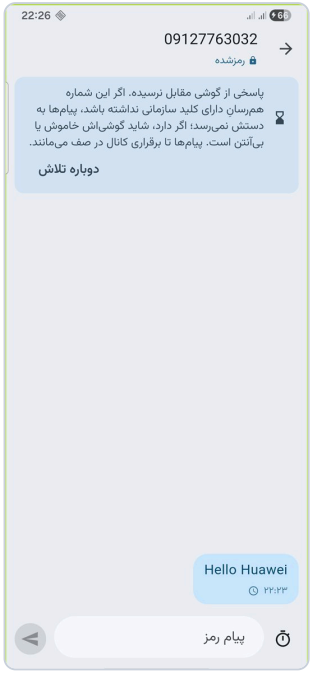
۱۲ «فایل کلید وارد شد»

گام ۴. اولین پیام رمز و حالت‌های شکست

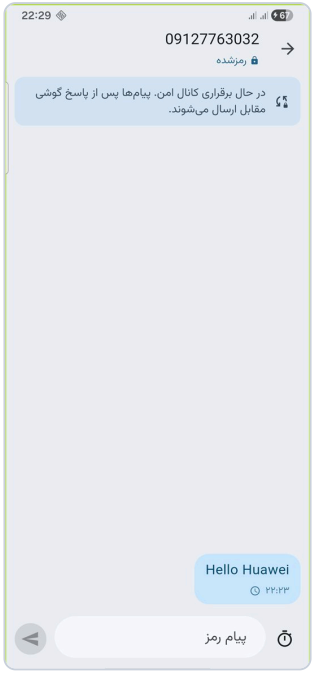
«پیام‌ها» ← «پیام‌های رمز» ← «گفتگوی رمز»: انتخاب از مخاطبین یا نوشتن شمارهٔ همراه. سامسونگ پیش از آنکه هواوی فایل کلیدش را وارد کند به او پیام داد؛ بعد از ۲ دقیقه «پاسخی از گوشی مقابل نرسیده» آمد. هواوی فایل را وارد کرد، سامسونگ «دوباره تلاش» را زد و پیام چند ثانیه بعد رسید و «دیده شد» گرفت.



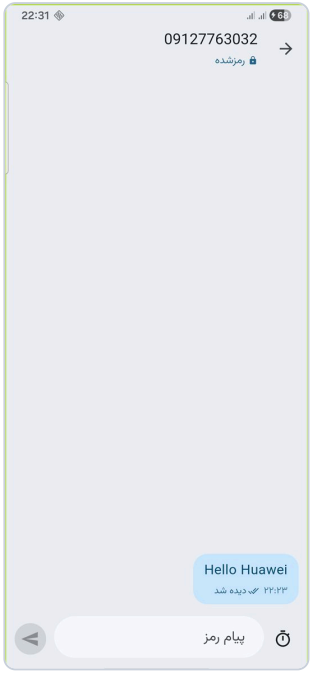
۱۳ «گفتگوی رمز»



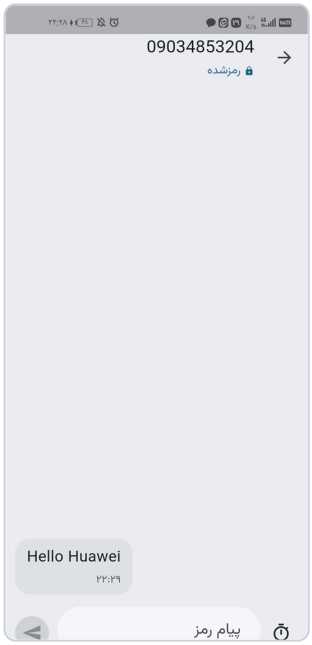
۱۴ «پاسخی نرسیده» و «دوباره تلاش»



۱۵ «در حال برقراری کانال امن»



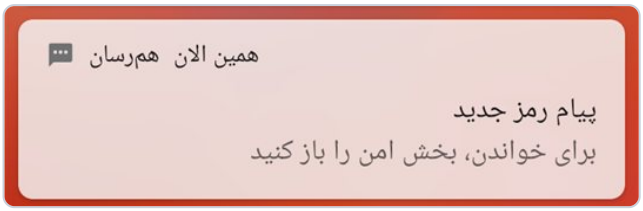
۱۶ پیام رسید و «دیده شد»؛ عنوان فقط «رمزشده»



۱۷ هواوی: پیام رسید

گام ۵. اعلان، زمان‌دار، حذف

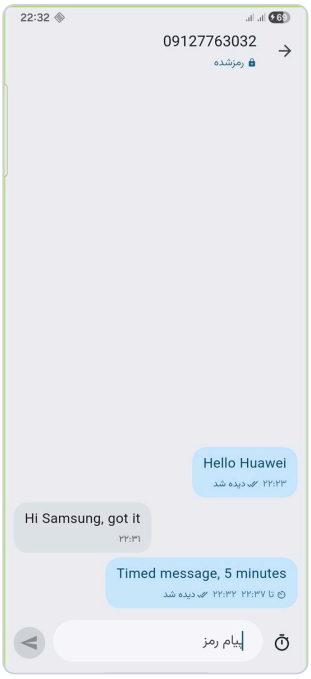
اعلان پیام رمز هیچ اطلاعاتی ندارد. با دکمهٔ «پاک شدن خودکار» کنار کادر نوشتن، پیام زمان‌دار یا «پس از دیدن» می‌شود. با نگه داشتن پیام خود، «حذف برای هر دو» در دسترس است.



۱۸ اعلان بدون نام و متن



۱۹ گزینه‌های پاک شدن خودکار



۲۰ پیام زمان‌دار: «تا ۲۲:۳۷»

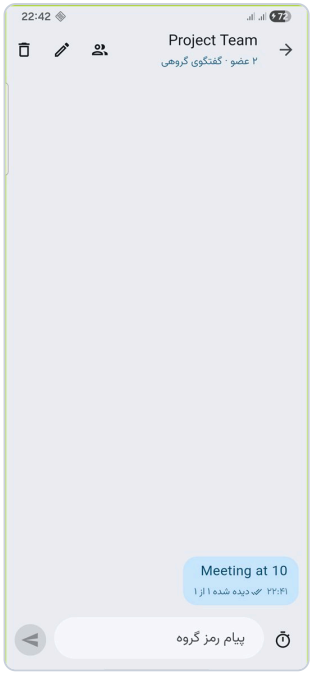


۲۱ «حذف برای هر دو»

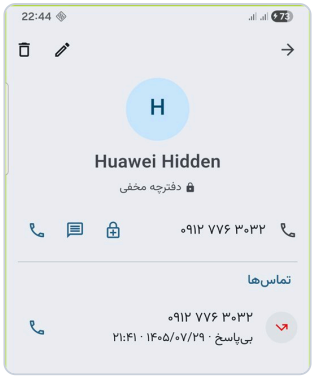
گام ۶. گروه رمز، دفترچهٔ مخفی و ابزارهای امنیتی



۲۲ ساختن گروه رمز



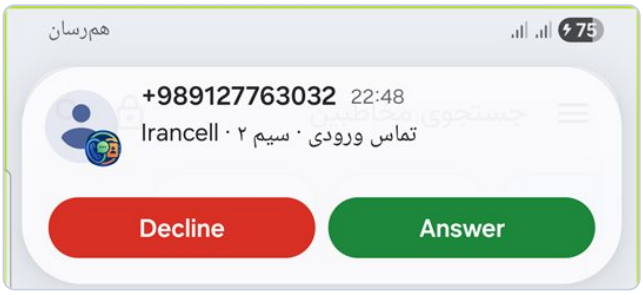
۲۳ «دیده شده ۱ از ۱»



۲۴ مخاطب مخفی: دو دکمهٔ پیام جدا



۲۵ «پیامک‌های رمزنشدهٔ مخفی» جدا از گفتگوی رمز



۲۶ تماس مخاطب مخفی با قفل بسته: فقط شماره



۲۷ کنترل امنیت سامانه

۱۵. تطبیق با پیوست فنی

ردیف	قابلیت	وضعیت	توضیح
۱	کد فعال‌سازی	انجام شد	قالب نرم‌افزار قبلی؛ بخش ۳
۳	آیکون قفل برای نمایش یا پنهان کردن بخش‌های رمز و مخفی	انجام شد	در همهٔ زبانه‌ها؛ بخش امن رمز جداگانه دارد
۱۱	رمزنگاری پیامک، دفترچهٔ مخفی و سوابق تماس بدون ثبت در سیستم‌عامل	انجام شد	بخش‌های ۶ و ۱۲
۱۲	رمزنگاری بانک اطلاعاتی برنامه	بخشی	بخش امن کامل رمز است؛ پیامک و مخاطبین عادی نه (بخش ۱۷)
۱۳	تغییر کلید با هر پیام و هر مخاطب	انجام شد	بخش ۶-۳
۱۴	پیام رمز گروهی	انجام شد	بخش ۱۱
۱۶	پیام رمز زمان‌دار	انجام شد	پاک شدن خودکار پس از مدت انتخابی؛ بخش ۱۳
۱۹	حذف دوطرفه	انجام شد	یک‌به‌یک و گروه
۲۰	حذف خودکار پیام دریافتی پس از دیدن	انجام شد	به انتخاب فرستنده برای هر پیام
۲۲	عدم امکان کپی و تصویربرداری	انجام شد	بخش ۸
۲۵	ارسال موقعیت و پاک‌سازی گوشی با پیامک خاص	انجام نشد	نیاز به تصمیم؛ بخش ۱۷
۲۹	کنترل امنیت سامانه	انجام شد	بخش ۱۳
۳۰	اطلاع فرستنده از رؤیت	انجام شد	«دیده شد»؛ یک‌به‌یک و گروه
۳۱	تبدیل متن رمز به متن پوششی (فقط سازمانی)	انجام شد	فارسی و انگلیسی؛ بخش ۷-۳
۳۲	عکس‌برداری پنهان پس از ۳ رمز اشتباه	انجام شد	هر دو دوربین؛ بخش ۱۳
۳۳	رمزنگاری پساکوانتومی	انجام شد	کانال امن اول کلاسیک (۴ تکه) ساخته و بی‌صدا در پس‌زمینه با ML-KEM-768 پساکوانتومی می‌شود؛ بخش ۶-۲
۳۵	دفترچهٔ تلفن اختصاصی رمزشده با پیامک و تماس بدون ثبت در سیستم‌عامل	انجام شد	بخش ۱۲
۳۶	گروه یا فیلتر پیش‌فرض برای مخاطبین و پیامک‌های رمز	بخشی	«پیام‌های رمز» و «دفترچه مخفی» جدا هستند. ردیف «مخاطبین رمز» به تصمیم مالک پروژه حذف شد: بدون فهرست اعضا، فقط راه دومی به «گفتگوی رمز» بود.

۱۶. آزمون‌ها

آزمون‌های خودکار (۱۴۰۵/۰۷/۲۹)

- ۱۲۱ آزمون سمت اندروید (JVM)، ۷۷۹ آزمون Dart، ۲۳ آزمون ابزار مرجع و ۱۲ آزمون پنل، همه موفق؛ `flutter analyze` بدون ایراد.
- بردارهای رسمی NIST برای ML-KEM-768 و ML-DSA-65 و بردارهای 5869، 8032، RFC 7748 و 9106؛ حملهٔ مرد میانی، دستکاری، تکرار و بی‌ترتیبی.
- بردارهای طلایی که قالب پیام، فایل کلید و مهروموم را قفل می‌کنند. قالب تازهٔ فایل کلید با شناسهٔ مرجع، شناسهٔ کلید عضو و هش کل فایل قفل شد.
- آزمون‌های فایل کلید: دو عضو که جدا از هم صادر شده‌اند با هم حرف می‌زنند؛ رمز اشتباه، مرجع ناشناس، فایل غیرکلید، کلیدی که گواهی نام نمی‌برد و گواهی مرجع دیگر رد می‌شوند.
- هفت آزمون «کانالی که برقرار نشود هرگز بی‌صدا نمی‌ماند»: درخواست ناموفق، درخواست بی‌پاسخ، «دوباره تلاش»، ارتقای گم‌شده و تکرار بی‌صدای آن، و پیشنهاد ارتقای دیررسیده (این آزمون پیش از اصلاح شکست می‌خورد و بعد از آن موفق است).
- آزمون‌های جدا ماندن پیامک عادی مخاطب مخفی از گفتگوی رمز و تغییر نام هر دو گفتگو.
- پنل: خودآزمایی نسخهٔ نصب‌شده (ساختن مرجع، دو عضو جدا از هم و کانال گواهی بین آن‌ها) و تصویرهای راهنمای پنل که از خود صفحه‌های پنل ساخته می‌شوند.

آزمون روی گوشی‌های واقعی (۱۴۰۵/۰۷/۲۹)

مرجع از نو ساخته شد و برای هر گوشی کلید تازه صادر شد. برنامه روی گوشی‌ها از نو نصب شد.

- **سامسونگ ↔ شیائومی:** فعال‌سازی، وارد کردن فایل‌های ۲۶۱ بایتی، شروع گفتگو با انتخاب از مخاطبین و با شمارهٔ تایپ‌شده، کانال گواهی بین دو عضوی که جدا صادر شده بودند، پیام در هر دو جهت و «دیده شد»، پیام «پاسخی نرسیده» بعد از ۲ دقیقه و «دوباره تلاش»، و تکرار بی‌صدای ارتقای گم‌شده و کامل شدن آن.
- **شمارهٔ بدون هم‌رسان:** فقط پیامک‌های نامفهوم درخواست رسید و فرستنده پیام «پاسخی نرسیده» گرفت.
- **سامسونگ ↔ هواوی (عضو تازه):** هواوی همان روز به سازمان اضافه شد و فقط فایل خودش را گرفت. فایل سامسونگ بایت به بایت عوض نشد. نتیجه: کانال امن، پیام در هر دو جهت، ارتقای پساکوانتومی (پاسخ و تأیید در کمتر از یک دقیقه)، پیام بعد از ارتقا در هر دو جهت، گروه رمز با پیام و پاسخ و «دیده شده ۱ از ۱»، پیام زمان‌دار (از هر دو گوشی سر وقت پاک شد)، حذف پس از دیدن، حذف برای هر دو، دفترچهٔ مخفی (پیامک عادی فقط در فهرست جدای خودش، جواب عادی به‌صورت پیامک معمولی، تماس‌های بی‌پاسخ فقط در «تماس‌های مخفی»)، و بعد از نصب نسخهٔ تازه، ادامهٔ همان کانال‌ها.
- در هیچ‌کدام از گوشی‌ها هیچ پیامک `#E:` در حافظهٔ پیامک اندروید نبود.

اشکال‌هایی که روی گوشی پیدا و همان روز رفع شد

۱. **پیشنهاد ارتقای دیررسیده جلسه را خراب می‌کرد (جدی).** یک پیشنهاد ارتقا در شبکه ماند و بعد از پیشنهاد تازه رسید. گوشی گیرنده با جواب دادن به آن، جلسه‌ای را پاک کرد که فرستنده از آن استفاده می‌کرد و از آن به بعد پیام‌های فرستنده خوانده نمی‌شد. حالا دو جلسهٔ آخر نگه داشته می‌شوند تا فرستنده روی یکی پیام بدهد (بخش ۶-۲). اول آزمونی نوشته شد که همین اشکال را بازتولید کرد.

۲. **ارتقای گم‌شده ۳۰ دقیقه منتظر می‌ماند.** حالا اگر از طرف مقابل پیامی برسد، ۲ دقیقه بعد دوباره پیشنهاد می‌شود.

۳. **پیامک عادی و پیام رمز یک مخاطب مخفی در یک گفتگو بودند** و درخواست کانال امن یک گفتگوی عادی را رمزی می‌کرد. حالا دو گفتگو و دو فهرست جدا هستند.

۴. **شکست کانال امن دیده نمی‌شد.** حالا دو پیام روشن با «دوباره تلاش» دارد. عنوان «در حال ارتقای پساکوانتومی» به خواست مالک پروژه برداشته شد.

مشاهده‌ها (رفع نشده، تغییری داده نشد)

- ساعت هواوی ۲ دقیقه عقب بود؛ در گفتگوی هواوی، جوابی که هواوی داد بالاتر از پیامی نشان داده شد که به آن جواب داده بود. روی سامسونگ ترتیب درست است.
- روی گوشی‌ای که هم‌رسان برنامهٔ پیش‌فرض تماس آن نیست، بعد از برگشتن از پنجرهٔ انتخاب فایل، پیشنهاد «برنامه تماس پیش‌فرض» دوباره نشان داده شد.
- پنجرهٔ تأیید حذف یک گفتگوی «پیامک رمزنشده» می‌گوید «گفتگوی رمز با … پاک می‌شود».

آزمون‌های پیشین

از ۱۴۰۵/۰۷/۰۵ تا ۱۴۰۵/۰۷/۲۶ بقیهٔ قابلیت‌ها روی شبیه‌ساز و دو گوشی واقعی آزموده شدند: فعال‌سازی با کدهایی که برنامهٔ جاوای مرجع ساخته بود، بخش امن و قفل آن، پیام و پاسخ، پیام زمان‌دار، حذف‌ها، گروه رمز، دفترچهٔ مخفی، عکس ورود ناموفق، کنترل امنیت، دوسیم‌کارته‌ها و به‌روزرسانی برنامه بدون از دست رفتن کانال‌ها. مشاهدهٔ شبکه: یک پیامک ۱۷ دقیقه در شبکهٔ اپراتور ماند و بعد رسید، و برنامه آن را درست و سر جای خودش نشان داد.

۱۷. محدودیت‌ها و تصمیم‌های باز

تصمیم‌هایی که برای پیش رفتن کار گرفته شد

موضوع	آنچه پیاده شد
رسیدن به عضو تازه بدون فایل برای همه	گواهی عضو؛ بدون دفترچه و بدون فایل به‌روزرسانی (بخش ۹-۳).
فهرست اعضا روی گوشی	«نمی‌خواهم نام مخاطبان رمز در برنامه یا در کلید باشد.» هیچ نام و فهرستی روی گوشی نیست؛ کاربر از مخاطبین خودش انتخاب می‌کند یا شماره را می‌نویسد.
تعداد پیامک اولین تماس	«باید خیلی کمتر شود، حتی به بهای پایین رفتن امنیت»: ۴ تکه، کلاسیک؛ لایهٔ پساکوانتومی بعداً در پس‌زمینه. گواهی فقط با Ed25519.
نمایش ارتقا	«در هدر هیچی نمایش نده جز رمزشده.» کاربر از وضعیت ارتقا خبر ندارد (بخش ۶-۵).
انقضا و ابطال گواهی	«نیازی به انقضا نیست؛ بیرون کردن عضو را بیخیال.» گواهی تاریخ انقضا ندارد و باطل نمی‌شود. پیامد: عضوی که از سازمان حذف شده، با فایل کلیدش هنوز به اعضا پیام رمز می‌دهد و پیام می‌گیرد. گوشی گم‌شده هم برای گوشی‌هایی که هنوز گواهی نسل تازهٔ صاحبش را ندیده‌اند معتبر می‌ماند.
رمز بخش امن	جدا از رمز برنامه؛ فراموشی آن یعنی از دست رفتن محتوای امن.
مرجع کلید	یک مرجع واقعی ساخته و کلید عمومی‌اش داخل برنامه گذاشته شد (بخش ۱۰). برنامه می‌تواند هم‌زمان چند مرجع را بپذیرد.
معنای «پیام زمان‌دار» و «کنترل امنیت سامانه»	پیامی که پس از مدت انتخابی خودبه‌خود پاک می‌شود؛ بررسی و گزارش وضعیت امنیتی گوشی.

محدودیت‌هایی که باید بدانید

- **فایل کلید عضو تازه هنوز باید جدا از پیامک به دستش برسد** (فلش، حضوری). این تنها چیزی است که بدون اینترنت از راه دیگری می‌رود؛ هیچ عضو دیگری فایل نمی‌خواهد.
- **نام در گفتگوهای رسیده:** گفتگویی که دیگری شروع کرده با شمارهٔ او نشان داده می‌شود، مگر اینکه در دفترچهٔ مخفی باشد. گفتگویی که خود کاربر از مخاطبین شروع کند، نام مخاطب را دارد.
- **جلسهٔ مشترک گم‌شده:** اگر دو گوشی به هر دلیلی (مثلاً پاک شدن بخش امن یکی) جلسهٔ مشترک نداشته باشند، پیام‌های گوشی دیگر خوانده نمی‌شود تا یکی از دو نفر گفتگو را حذف و دوباره شروع کند. بازیابی خودکار این حالت هنوز ساخته نشده است.
- **چند مرجع:** گوشی‌ای که کلید دو مرجع (دو سازمان) را دارد، به درخواست با گواهی اولین مرجع جواب می‌دهد. اگر درخواست‌دهنده فقط به مرجع دوم اعتماد کند، کانال ساخته نمی‌شود.
- **شمارهٔ عضویت:** گواهی فقط برای اولین شمارهٔ همراه عضو است. در گوشی دوسیم‌کارته، پیام رمز باید از سیم همان شماره برود (منوی «پیام‌های رمز»).
- **پیام‌های پیش از ارتقا** فقط کلاسیک‌اند (بخش ۶-۵).

موضوع‌هایی که هنوز تصمیم شما را لازم دارند

- **ردیف ۲۵، فرمان پیامکی برای ارسال موقعیت و پاک کردن گوشی:** پیاده نشده است. اگر درست طراحی نشود، به هر کس که پیامک خاص را بداند اجازهٔ پاک کردن گوشی یا ردیابی صاحبش را می‌دهد. پیشنهاد ما: فقط با پیام رمز از یک عضو تعیین‌شده کار کند و پیش از اجرا تأیید بخواهد.
- **امنیت کد فعال‌سازی:** قالب فعلی با مهندسی معکوس قابل جعل و غیرقابل باطل کردن است (بخش ۳). جایگزین: کد امضاشده با طول ۲۰ تا ۳۰ نویسه که به تغییر برنامهٔ ویندوزی نیاز دارد.
- **نگهداری کلید نزد مرجع:** مرجع می‌تواند کلید خصوصی هر عضو را بازسازی کند. جایگزین این است که هر عضو کلیدش را روی گوشی خودش بسازد و مرجع فقط کلید عمومی او را امضا کند؛ ثبت‌نام اعضا چند مرحلهٔ بیشتر دارد.
- **امضای پساکوانتومی گواهی:** امروز گواهی فقط Ed25519 دارد. کسی که روزی کامپیوتر کوانتومی داشته باشد، از روی کلید عمومی مرجع می‌تواند گواهی جعلی بسازد. افزودن ML-DSA اولین تماس را به حدود ۳۰ تکه می‌رساند.
- **محافظت پساکوانتومی در برابر سرقت هم‌زمان کلیدها:** حدود ۲۰ پیامک به هر کانال اضافه می‌کند و مثل ارتقای فعلی می‌تواند در پس‌زمینه برود. لازم است؟
- **ردیف ۱۲:** آیا پیامک‌ها و مخاطبین عادی هم باید در پایگاه‌دادهٔ رمزشده باشند؟ این محتوا در هر صورت در حافظهٔ خود اندروید هم هست.
- **ابطال:** اگر روزی بیرون کردن عضو لازم شد، بدون اینترنت فقط با پخش یک «فهرست ابطال» امضاشده به همه ممکن است، که دوباره فایلی برای همه می‌شود.
- **آزمون کد فعال‌سازی با برنامهٔ ویندوزی شما:** برای کد دستگاه `b60966` باید `9c4a48e93a` به دست آید.

۱۸. واژه‌نامه

اصطلاح	معنی
AES-256-GCM	رمز متقارن استاندارد با کلید ۲۵۶ بیتی. حالت GCM دستکاری را هم تشخیص می‌دهد.
ANDROID_ID	شناسهٔ ۱۶ نویسه‌ای که اندروید به هر برنامه روی هر گوشی می‌دهد. پایهٔ کد دستگاه است.
APK	فایل نصبی برنامهٔ اندروید.
Argon2id	الگوریتمی که رمز تایپ‌شده را به کلید تبدیل می‌کند و حدس زدن رمز را عمداً گران می‌کند.
Base64	روشی برای نوشتن داده‌های دودویی با حروف و ارقام لاتین تا در پیامک جا شوند.
BLAKE3، SHA-256	توابع هش: اثر انگشت کوتاه و یکتای داده.
FLAG_SECURE	تنظیم اندروید که اسکرین‌شات و فیلم‌برداری از صفحه را سیاه می‌کند.
HKDF، HMAC	روش‌های استاندارد ساختن کلیدهای جدا از یک راز.
ML-KEM، ML-DSA	الگوریتم‌های پساکوانتومی استاندارد NIST برای توافق کلید و امضا.
nonce	عددی که برای هر بار رمز کردن فقط یک بار به کار می‌رود.
PBKDF2	الگوریتم قدیمی‌تر تبدیل رمز به کلید که برای رمز بخش امن به کار رفته است.
ratchet	زنجیرهٔ کلید: با هر پیام یک قدم جلو می‌رود و برای هر پیام کلید تازه می‌سازد.
salt	عدد تصادفی که کنار رمز گذاشته می‌شود تا رمزهای یکسان کلید یکسان نسازند.
seed	عدد تصادفی کوتاهی که یک کلید کامل از آن ساخته می‌شود.
SQLCipher	پایگاه‌دادهٔ رمزشده‌ای که محتوای بخش امن در آن است.
TEE، StrongBox، Keystore	بخش‌های سخت‌افزاری امن گوشی که کلید داخلشان ساخته می‌شود و هرگز بیرون نمی‌آید.
X25519، Ed25519	الگوریتم‌های کلاسیک و آزمودهٔ توافق کلید و امضا بر پایهٔ منحنی بیضوی.
بانک کلید	بخشی از برنامه که فایل کلید واردشدهٔ خود کاربر را نگه می‌دارد.
بخش امن	قسمت قفل‌دار برنامه با رمز جداگانه که همهٔ محتوای محرمانه در آن است.
بردار طلایی	ورودی و خروجی ثابتی در آزمون‌ها که تغییر ناخواستهٔ قالب را آشکار می‌کند.
پساکوانتومی	مقاوم در برابر کامپیوتر کوانتومی.
ترکیبی (hybrid)	به کار بردن هم‌زمان یک الگوریتم کلاسیک و یک الگوریتم پساکوانتومی، طوری که شکستن یکی کافی نباشد.
شناسهٔ کلید	۸ بایت اول هش کلید X25519 یک نفر؛ نام او در گواهی، بسته‌ها و گروه‌ها.
فایل کلید (.hkb)	فایل ۲۶۱ بایتی و رمزدار هر عضو: کلید خصوصی او و گواهی عضو او.
کانال امن	کلید مشترکی که دو نفر یک بار با تبادل دو بستهٔ ۲ تکه‌ای (گواهی هر کدام) می‌سازند.
گواهی عضو	امضای ۱۰۳ بایتی مرجع روی شمارهٔ همراه، نسل و کلید یک عضو؛ عضو را بدون هیچ فهرستی به طرف مقابل معرفی می‌کند.
ارتقای پساکوانتومی	سه بستهٔ کنترلی (۱۱ + ۱۰ + ۱ تکه) که بعد از ساخته شدن کانال، بی‌صدا در پس‌زمینه یک راز ML-KEM به آن اضافه می‌کنند.

کد دستگاه، کد فعال‌سازی	کد ۶ نویسه‌ای هر گوشی و کد ۱۰ نویسه‌ای که نسخهٔ بین‌سازمانی را روی آن باز می‌کند.
مرجع کلید	شخص یا واحدی که با پنل صدور کلید اعضا را صادر و گواهی‌شان را امضا می‌کند.
متن پوششی	شکل ظاهری دیگری از پیام رمز که شبیه کلمه‌های عادی است (فقط سازمانی).
مهروموم (SealedBox)	رمز کردن با کلید عمومی بخش امن، طوری که فقط بعد از باز شدن قفل خوانده شود.